

Marco del Sistema de Gestión de Seguridad de la Información (SGSI) - NovaTech Solutions

Este documento funciona como la arquitectura del sistema y establece la estrategia para el blindaje organizacional de NovaTech Solutions, aquí se abordan los procesos para gestionar la seguridad de forma sistemática y proteger los activos críticos contra riesgos significativos.

1. Contexto de la Empresa

NovaTech Solutions es una organización mexicana ubicada en Monterrey, dedicada al desarrollo de software y servicios digitales para PyMEs. Con un equipo de 120 empleados, el crecimiento acelerado de la empresa ha generado la necesidad de implementar un SGSI formal, ya que la dirección general ha identificado debilidades estructurales que deben corregirse.

La organización está dividida en tres departamentos principales:

- **Desarrollo de Software:** Responsable de plataformas web, mantenimiento de aplicaciones y gestión de repositorios de código.
- **Atención a Clientes:** Manejan los datos personales de los usuarios a mediante el sistema de soporte y CRM.
- **Administración:** Se encargan de las facturas, pagos, contratos legales y la información de los empleados.

2. Alcance del SGSI

Este sistema de seguridad cubre los procesos más importantes, la información sensible manejada por la empresa y la tecnología que los hace funcionar. Específicamente, los activos protegidos son:

- Datos personales de clientes.
- Información financiera.
- Sistemas web.
- Propiedad intelectual.
- Infraestructura tecnológica crítica.
- Código fuente y documentos contractuales.
- Credenciales de acceso.

3. Objetivos de Seguridad (Tríada CIA)

Nuestra meta es proteger a NovaTech basándonos en tres pilares:

Pilar de Meta para NovaTech	
Seguridad	
Confidencialidad	Asegurar que el código, información sensible de la empresa y los datos personales solo sean vistos por las personas autorizadas.
Integridad	Asegurar que el dinero, los contratos y las configuraciones de los sistemas no se alteren sin autorización.
Disponibilidad	Mantener los servicios web y el sistema de clientes siempre funcionando para no perder ventas ni tiempo.

4. Equipo y Responsabilidades

El diseño y la implementación del sistema depende de nuestro Comité de Seguridad, donde cada uno tiene sus respectivas funciones:

- **Roel Antonio Guzman Martinez (Coordinación):** Define el plan general, el alcance y dirige cómo se organiza todo para que siempre mejore.
- **Emiliano Villarreal Saracco (Gestión de Riesgos):** Se encarga de identificar qué información es crítica, qué amenazas nos rodean y qué herramientas técnicas usaremos para defendernos.
- **Eva Dayane Rodríguez Hernández (Cumplimiento y Cultura):** Su trabajo es asegurar que cumplamos con las leyes de datos personales, redactar las reglas internas y fomentar los programas de capacitación.
- **Renata Alvarez Del Castillo Garza (Especialista en Respuesta a Incidentes):** Encargada de los planes para reaccionar ante ataques, asegurar que el negocio siga operando si algo falla y medir qué tan bien vamos.

5. Situación Actual de Seguridad

Por medio de una revisión interna, se identificó que la organización pasa por una situación preocupante que representa un riesgo significativo:

- **Controles tecnológicos aislados:** Tenemos medidas técnicas funcionando, no están bien integradas entre sí.
- **Ausencia de políticas formales:** Nos faltan reglas claras que digan cómo se espera que actuemos en el día a día.
- **Análisis de riesgos inexistente:** Hasta no se ha hecho una evaluación formal de las amenazas que realmente podrían afectar al negocio.

- **Capacitación limitada en seguridad:** El equipo no ha recibido el entrenamiento suficiente y, sin querer, eso puede llevarnos a cometer errores humanos importantes.

6. Alineación Normativa y Metodológica

Para trabajar con estándares de calidad mundial, usamos tres guías principales:

1. **ISO/IEC 27001:** Es la norma internacional que nos da los pasos para organizar todos nuestros documentos y seguridad.
2. **Método OCTAVE Allegro:** La forma en la que analizamos los peligros, enfocándonos en lo que más impacta al negocio.
3. **Ley de Datos Personales (LFPDPPP):** La ley mexicana que nos obliga a cuidar la privacidad de nuestros clientes y trabajadores.

7. Mejora Continua (Ciclo PDCA)

El sistema se gestiona mediante un ciclo continuo que permite mantener su efectividad operativa:

- **Plan (Planear):** Establecer la estructura documental necesaria, así como las políticas y los objetivos de seguridad.
- **Do (Hacer):** Llevar a la práctica los controles definidos y poner en funcionamiento los procesos de capacitación.
- **Check (Verificar):** Realizar auditorías internas y evaluar el cumplimiento a través de métricas .
- **Act (Actuar):** Aplicar los ajustes y mejoras necesarios a partir de lo observado, para así fortalecer el blindaje de la organización.